AI GOVERNANCE READINESS ASSESSMENT

AI Governance Check and AI Governance Readiness Assessment — blueprint

Internal reference: services, method, sizing and proposal set. A decision per AI system — no single governance grade and no compliance statement.

1 **Where it sits**
AI governance in the 360 architecture; AI Readiness versus AI Governance; regulatory scope; seven recurring patterns. p. 2 – 6

2 **Two services**
Governance Check and Governance Readiness Assessment; five gate items mapped to the ten dimensions. p. 7 – 11

3 **Method**
Ten dimensions, ladder, evidence, phases, gate per AI system, governance matrix, lifecycle gates, routing. p. 12 – 22

4 **Komtaş side**
Roles, duration, effort and sizing, deliverables and proposal set, limits, package status and open items. p. 23 – 28

SECTION 1

Where It Sits

Where AI governance sits in the data and AI value proposition, how it differs from AI Readiness, the regulatory scope as of October 2026, and the patterns the services are built to show.

Where this service sits — 360 p. 3

AI Readiness and AI Governance Readiness p. 4

Regulatory scope as of October 2026 p. 5

Seven recurring patterns in AI governance p. 6

Where This Service Sits — AI Value Proposition

KOMTAS

Governance does not measure a layer. It is the control plane over the AI systems that act and decide in the top two layers.

Action 360

Intelligent Work Experience

SCOPE

Teams | Slack | WhatsApp | Web / Portal | Claude Desktop | API, Headless

Agent 360

Governed Digital Workforce

SCOPE

SECTOR: Banking | Insurance | Holdings, EU | Telecom | Healthcare | Other

AI SYSTEM: Chatbot | Scoring | Document AI | Agents | Vendor, embedded | Shadow AI

Context 360

Enterprise Context

LINEAGE

Semantic Layer | Ontology | Knowledge Graph | Master Data | Corporate Memory

Data / Analytic 360

Trusted Data Foundation

LINEAGE

Lakehouse | Datawarehouse | Integration | Data Virtualization | Governance / MDM | Access Control

Governance covers what runs in the top two layers. It reaches the bottom two only for the lineage and legal basis of the data these systems use.

LOGIC OF THE ASSESSMENT

Top two layers — under control?

Each AI system that acts or decides here is known, classified, approved and monitored — or the gap is shown.

Bottom two layers — lineage and legal basis

Only where a system's data comes from and on what basis. Data quality and catalogue belong to data governance.

Readiness versus governance

AI Readiness asks whether the top layers can start; AI Governance asks whether what already runs there is under control.

AI Readiness and AI Governance Readiness

KOMTAS

One asks “can it be done”, the other “can it be controlled”. A funnel, not an overlap

	AI READINESS	AI GOVERNANCE READINESS
What is assessed	Prerequisites for starting AI use cases	Control over the AI systems already in use
Core question	Can AI be started?	Can what is in production be governed?
Main evidence	Use case documents, data access records, interviews	Inventory, approval and incident records, contracts, interviews
Main output	A start decision per use case	Inventory, classification and control gaps per AI system
Place of governance	One of ten dimensions (A8)	The whole work
Typical organisation	No AI system in production, or a few	More than one system in production
Services	Readiness Check · Readiness Assessment	A Governance Check 1 – 2 weeks · B Governance Readiness Assessment 3 – 4 weeks
Main audience	CDO, CTO, business unit managers	Risk, legal, compliance, CIO / CDO, AI committee

NOT SOLD AT THE SAME TIME

An organisation is either at the point of starting AI or of governing what has started. Offered together, the scopes overlap and the organisation cannot tell which measures what. Which one fits is settled in the first meeting; AI Readiness's A8 routes here when weak.

NOT DATA GOVERNANCE, NOT MODEL RISK MANAGEMENT

Data governance asks who owns the data and whether it is correct; model risk management asks how large a statistical model's error is. AI governance asks whether the organisation has the right and the capacity to use each AI system. None replaces the others.

Regulatory Scope — As of October 2026

KOMTAS

Summary of the value deck, used for B's regulatory scope map per AI system. Not legal advice; the dates are reconfirmed before every proposal.

DATE	EU AI ACT · WHAT APPLIES
01.08.2024	Regulation entered into force; phased application started
02.02.2025	Prohibited practices (Art. 5) and AI literacy (Art. 4)
02.08.2025	GPAI obligations; AI Office and penalty framework
02.08.2026	Art. 50 transparency: synthetic content notice, informing users
02.12.2026	End of transition for existing generative systems (Art. 50(2) marking)
02.12.2027	Annex III high-risk systems — postponed by the Omnibus
02.08.2028	Annex I high-risk systems embedded in products
02.08.2030	High-risk systems used by public authorities

DIGITAL OMNIBUS (2026) CHANGED THE CALENDAR

- Annex III high-risk: 02.08.2026 → 02.12.2027
- Annex I embedded systems: 02.08.2027 → 02.08.2028
- Art. 50 transparency not postponed — started 02.08.2026

WHY IT CONCERNS AN ORGANISATION IN TÜRKİYE

The regulation can also cover systems whose output is used in the EU, and EU customers have started to ask about it in supplier assessments.

TÜRKİYE · NO AI-SPECIFIC LAW IN FORCE

- KVKK guide on generative AI and personal data (November 2025)
- KVKK guide on agentic AI (12 March 2026); both guides are non-binding
- Covered indirectly through KVKK (Law 6698), TCK, FSEK, consumer and competition law
- TBMM AI Research Commission report (March 2026) proposes a framework law

REGULATOR	AREA	TYPICAL AI USE
KVKK	Personal data, legal basis, notice, DPIA	Any system processing personal data
BDDK	Banking IT and e-banking rules	Credit scoring, fraud detection, automation
SPK	Capital market activities	Robo-advice, algorithmic trading
Ministry of Health	Medical device rules, certification	Diagnosis support, image analysis
TCMB · BTK · RTÜK	Payments, e-communication, broadcasting	Payment risk, subscriber analytics, synthetic media

NO LAW DOES NOT MEAN NO OBLIGATION

An AI system that processes personal data is already within KVKK; sector IT and risk rules also apply to processes run with AI.

HOW B USES THIS · per AI system: EU AI Act exposure, KVKK and the applicable sector regulator, each marked evidence provided / partial evidence / no evidence produced. No compliance statement; the organisation's legal and compliance interpret.

Seven Recurring Patterns in AI Governance

KOMTAS

Each is measurable; the assessment is not done to spot them but to show them with evidence

Principles on the wall

An ethics principle text is written and governance is assumed to exist. A principle text is not a control; a control is someone approving at a gate.

Measured: systems that passed a written approval step

Inventory smaller than use

Individual subscriptions, calls embedded in spreadsheets and AI inside vendor products stay outside the inventory.

Measured: systems found in the search versus systems recorded

Classified by model, not by use

The same language model is minimal risk in document summarisation and can be high risk in recruitment. A class per model hides this.

Measured: records with class, rationale and date per use

Approval that never rejects

An approval step exists but no request has ever been rejected or returned. That is record keeping, not control.

Measured: requests rejected or returned at a gate

No business owner

The technical owner is known; the person on the business side who owns the system's results is not. When an error occurs, responsibility is debated.

Measured: systems with a named business owner

Vendor AI not recorded

AI inside a purchased product is the organisation's responsibility too; who commits to what in the contract is not recorded.

Measured: vendor AI components with a reviewed contract

In production, no way back

Systems run in production without a metric, a threshold or a rollback plan; nobody knows how to switch them off in a controlled way.

Measured: production systems with a metric, threshold and rollback plan

ALL SEVEN HAVE THE SAME ROOT

None is a tool or technology problem. All seven arise because a decision about a system was not recorded against a named person: who owns it, which class it is, who approved it, who watches it and how it is stopped. The assessment asks for each of them per system.

SECTION 2

Two Services

AI Governance Check and AI Governance Readiness Assessment — what each covers, how long it takes, and how the five gate items map to the ten dimensions.

Which one fits p. 8

A · AI Governance Check p. 9

B · AI Governance Readiness Assessment p. 10

Gate items mapped to the ten dimensions p. 11

Two Services — Which One Fits

AI Governance Check and AI Governance Readiness Assessment. Each can be taken on its own; neither is a mandatory step before the other.

02 · TWO SERVICES

p. 9

A AI Governance Check

Five-item gate per declared AI system · documents and interviews

Focus	Five gate items, checked per declared AI system
Scope	5 gate items for each AI system the organisation declares
Result	Met / partly / not met; indicative result and risk class per system
Access	None · documents and interviews; declared systems only
Effort	Komtaş 6 · 9 · 12 pd · customer 3 · 4 · 5 days
Evidence	Statement · Document · Observation · Measurement
Weeks	S 1 · M 1.5 · L 2 — *pending delivery confirmation*

p. 10

B AI Governance Readiness Assessment

Decision per AI system · shadow AI search · closing plan

Focus	Governance matrix, closing plan and target gate model
Scope	10 dimensions at organisation level; gate per AI system
Result	Ladder, gate per system, governance matrix with priority
Access	None · documents, interviews, observation; inventory, approval and incident records if shared
Effort	Komtaş 22 · 28 · 34 pd · customer 6 · 8 · 10 days
Evidence	Statement · Document · Observation · Measurement
Weeks	S 3 · M 3.5 · L 4 — *pending delivery confirmation*

WHICH ONE FITS · THE QUESTION ON THE TABLE DECIDES

Is a quick, documented view needed of whether the declared AI systems meet the five gate items? → A

Is a decision per AI system needed — including shadow and vendor AI, a closing plan and a target gate model? → B

A · AI Governance Check

Five-item gate per declared AI system · documents and interviews.

KOMTAS

02 · TWO SERVICES · A

A

AI Governance Check

Five gate items, checked per declared AI system

WEEKS S · M · L	KOMTAŞ EFFORT person-days	CUSTOMER days
1 · 1.5 · 2	6 · 9 · 12	3 · 4 · 5

Internal figures, pending delivery confirmation

WHAT IS CHECKED · 5 GATE ITEMS PER DECLARED AI SYSTEM

1 Registered

The system is recorded in an inventory with a named business owner and technical owner

D1 · D4

2 Classified

Purpose and affected decision written; risk class assigned with rationale and date

D2

3 Lawful data use

Data sources, personal data status and legal basis written (DPIA where needed); contract constraints checked for third-party AI

D6 · D9

4 Approved with a way back

A named approver approved production use; a human oversight point and a rollback / switch-off plan exist

D3 · D8

5 Monitored

At least one metric with a threshold, an incident path and a periodic review date

D8

Σ Per declared AI system

Each item is checked separately for every system the organisation declares; shadow AI is not searched in A.

«AI SYSTEMS»

HOW IT IS ASSESSED

Four statuses per gate item and system

- Met
- Partly met
- Not met
- Not assessed

Indicative result per system — governed, partly governed, not governed — and a provisional risk class, both statement-based.

WHAT YOU GET

- Gate status per declared system, item by item
- Indicative result and provisional risk class per system
- Key risks, each with its evidence
- Recommended next step, incl. whether B is worth taking

No ladder, no closing plan, no shadow AI search. If no AI system is in use or planned for production, P0 stops: AI Readiness fits.

B · AI Governance Readiness Assessment

Decision per AI system · shadow AI search · closing plan.

02 · TWO SERVICES · B

B

AI Governance Readiness Assessment

Governance matrix, closing plan and target gate model

WEEKS S · M · L	KOMTAŞ EFFORT person-days	CUSTOMER days
3 · 3.5 · 4	22 · 28 · 34	6 · 8 · 10

Internal figures, pending delivery confirmation

WHAT IS ASSESSED · 10 DIMENSIONS, ORGANISATION LEVEL

D1 AI inventory & registration
Systems known, recorded and owned

D2 Risk classification & impact assessment
Class per use, rationale, date

D3 Policy, standards & approval mechanism
Written policy, usage rules, approval

D4 Roles & accountability
Who approves, monitors, stops

D5 Documentation & transparency
System card, limits, user notice

D6 Data sources, legal basis, copyright & consent
Sources, personal data, basis, DPIA

D7 Testing, bias & acceptance criteria
Evaluation set, bias, thresholds

D8 Production monitoring & incident management
Drift, incidents, rollback, switch-off

D9 Third-party & supply chain AI
Vendor models, embedded AI, contracts

D10 Regulatory tracking & audit readiness
Regulation watch, evidence capacity

HOW IT IS ASSESSED

Current and target level per dimension

1	2	3	4	5

current: 2
target: 3

Then the gate per AI system and the governance matrix: governed, partly or not governed, with priority.

WHAT YOU GET

- Ten dimensions, current and target level
- Governance matrix with risk class and regulatory scope
- Closing plan and target gate model by risk class
- Routing to follow-on work

No weighted score. Inventory exports, approval and incident records and monitoring dashboards are used as measurement where shared.

Gate Items Mapped to the Ten Dimensions

KOMTAS

A checks the five gate items, which touch seven of the ten dimensions. B places all ten and runs the same gate with deeper evidence, so A's result carries into B.

DIMENSION	A · GATE ITEM	EVIDENCE IN A · DOCUMENTS, INTERVIEWS	EVIDENCE IN B · DEEPER, PER SYSTEM
D1 **AI inventory & registration**	1 Registered	Declared system list, inventory if any	Shadow and vendor AI search; inventory fields checked per record
D2 **Risk classification & impact assessment**	2 Classified	Statement of purpose and decision	Risk class per system with rationale; re-classification practice
D3 **Policy, standards & approval mechanism**	4 Approved	Policy, approval procedure	Approval records; rejected or returned requests
D4 **Roles & accountability**	1 · 4 Owners · approver	Role definitions, owner interviews	Role at each lifecycle gate; committee minutes
D5 **Documentation & transparency**	*Not checked in A*	—	System or model card, written limits, user notice
D6 **Data sources, legal basis, copyright & consent**	3 Lawful data use	Legal basis statement, DPIA if any	Legal basis and DPIA per system; copyright and consent
D7 **Testing, bias & acceptance criteria**	*Not checked in A*	—	Evaluation set, acceptance criterion, bias analysis
D8 **Production monitoring & incident management**	4 · 5 Way back · monitored	Rollback plan, monitoring statement	Dashboards, incident log, review minutes, if shared
D9 **Third-party & supply chain AI**	3 Contract constraints	Vendor list, contract statement	Vendor contracts; AI features in purchased products
D10 **Regulatory tracking & audit readiness**	*Not checked in A*	Applicable regulators, statement only	Regulatory scope map per system; evidence production capacity
EVIDENCE DEPTH		Documents and interviews — declared systems only	Plus observation, shadow AI search and, where shared, inventory, approval and incident records
RESULT FORMAT		Status per gate item and system; indicative result	Level per dimension; gate; governance matrix with priority

A covers the five gate items for every system named in «AI SYSTEMS». A dimension left out of B's scope is named in the proposal as «OUT-OF-SCOPE DIMENSION» (4b).

SECTION 3

Method

The ten dimensions, the evidence rules, the phases, the gate per AI system, the governance matrix, lifecycle gates by risk class, report contents and routing.

Ten dimensions · maturity ladder · evidence model — p. 13 – 15

How it is run · phase rules — p. 16 – 17

Gate per AI system · governance matrix · lifecycle gates by risk class — p. 18 – 20

Report contents · routing — p. 21 – 22

Ten Dimensions

KOMTAS

The checklist behind B, placed on the ladder at organisation level; seven of them carry the gate items that A checks per system. There are no weights and no score.

	DIMENSION	TOPICS COVERED
D1	**AI inventory & registration**	Whether all AI systems in use are known and recorded with the inventory fields; owners per record; shadow and vendor AI
D2	**Risk classification & impact assessment**	Risk class per use, not per model, with rationale and date; impact assessment; re-classification when the purpose changes
D3	**Policy, standards & approval mechanism**	Written policy and usage rules; production approval by a named approver; whether any request has ever been rejected
D4	**Roles & accountability**	AI committee, business owner, technical owner, DPO, legal, risk, security, internal audit: the role at each gate written down
D5	**Documentation & transparency**	Technical documentation, model or system card, written limits, user notice where people interact with AI
D6	**Data sources, legal basis, copyright & consent**	Data sources and personal data status; legal basis, notice and DPIA; copyright and consent for training and input data
D7	**Testing, bias & acceptance criteria**	Evaluation set and acceptance criterion written before testing; bias and error analysis; release thresholds
D8	**Production monitoring & incident management**	Metric and threshold monitoring, drift, incident record and response, rollback and switch-off, periodic review
D9	**Third-party & supply chain AI**	Vendor models and AI inside purchased products; what each party commits to in the contract; vendor review
D10	**Regulatory tracking & audit readiness**	Who follows the EU AI Act, KVKK and sector rules; capacity to produce evidence for an audit or a customer questionnaire

WHY THE FIRST TWO COME FIRST

An unknown system cannot be governed, and obligations follow from the class. Without an inventory there is no classification, and without classification the gates cannot be designed. The remaining dimensions decide how well control works.

Five-Level Maturity Ladder

KOMTAS

Used in the Governance Readiness Assessment (B): each dimension is placed on this ladder at organisation level. A uses no ladder. Without evidence, one level lower is recorded.

LEVEL 1
Ad hoc

No rule; result depends on people

- No written standard; practice varies by team
- Problems are solved by improvisation
- Not measured; state unknown

Exit: practice written down

LEVEL 2
Repeatable

Done the same way, but not written

- Experienced people follow the same method
- A newcomer cannot repeat the result
- Measurement, if any, is irregular

Exit: rule documented and owned

LEVEL 3
Defined

Rule written and applied

- Standard is documented and known
- Deviation from practice is noticed
- Regular measurement, no thresholds

Exit: thresholds set, deviation measured

LEVEL 4
Managed

Measured, with thresholds; deviation visible

- Thresholds defined and monitored
- Deviation detected automatically
- Root cause analysis is done

Exit: correction automated

LEVEL 5
Optimised

Deviation corrected automatically; continuous improvement

- Correction largely automated
- Thresholds updated from data
- Improvement shown by measurement

A LEVEL ALONE DOES NOT DECIDE

Even with high organisation levels, a system that fails a gate item is not governed. The ladder shows how well control works across the organisation; the gate decides, system by system, whether a system is under control.

THE TARGET LEVEL IS THE ORGANISATION'S DECISION

Gates scale with risk class, and so do target levels. An organisation with only minimal-risk systems does not need level four in testing; high-risk systems in production usually raise the target in D1, D2, D4 and D8.

Evidence Model

KOMTAS

Each finding is tied to an evidence type and shown in the report. Regulatory statements use only the three-state scale — never “compliant”.

MEASUREMENT
Measurement

A number from records — B only, if shared

· Inventory exports, approval and incident records, monitoring dashboards, licence and expense records

Highest confidence

DOCUMENT
Document

An existing document or record

· Policy, approval procedure, role definition, system card, DPIA, vendor contract

High confidence · currency checked

OBSERVATION
Observation

A process followed end to end — B

· One system followed from request to production, one approval or one incident traced

Medium confidence · one-off observation

STATEMENT
Statement

What people say

· Business and technical owner, committee, DPO, legal and risk interviews; unit survey

Low confidence · cannot confirm a level alone

THREE-STATE EVIDENCE SCALE

Evidence provided
Gate item or obligation shown by a document or record

Partial evidence
Evidence exists, but its scope is narrow or its currency unclear

No evidence produced
Not recorded — this is itself a finding

THE MOST FREQUENTLY CHECKED STATEMENT IS “IT WAS APPROVED”

It is checked by asking for the approval record with the approver's name and date, and whether any request has ever been rejected.
If no record can be shown, the item is marked statement-based.

“NOT RECORDED” IS AN ANSWER

If no inventory, approval record or incident log is kept, that is not a measurement gap but a governance finding.
The report does not fill it with an estimate; it states “no evidence produced” and sets the level accordingly.

How It Is Run — One Method, Two Depths

KOMTAS

The same evidence types, gate and phases are used in both services. The service sets how deep the evidence goes and how long each phase takes.

03 · HOW IT IS RUN

FOUR KINDS OF EVIDENCE

Measurement
B

Inventory exports, approval and incident records — if shared

Document
A · B

Policy, approval procedure, role definition, DPIA, vendor contract

Observation
B

One system followed from request to production

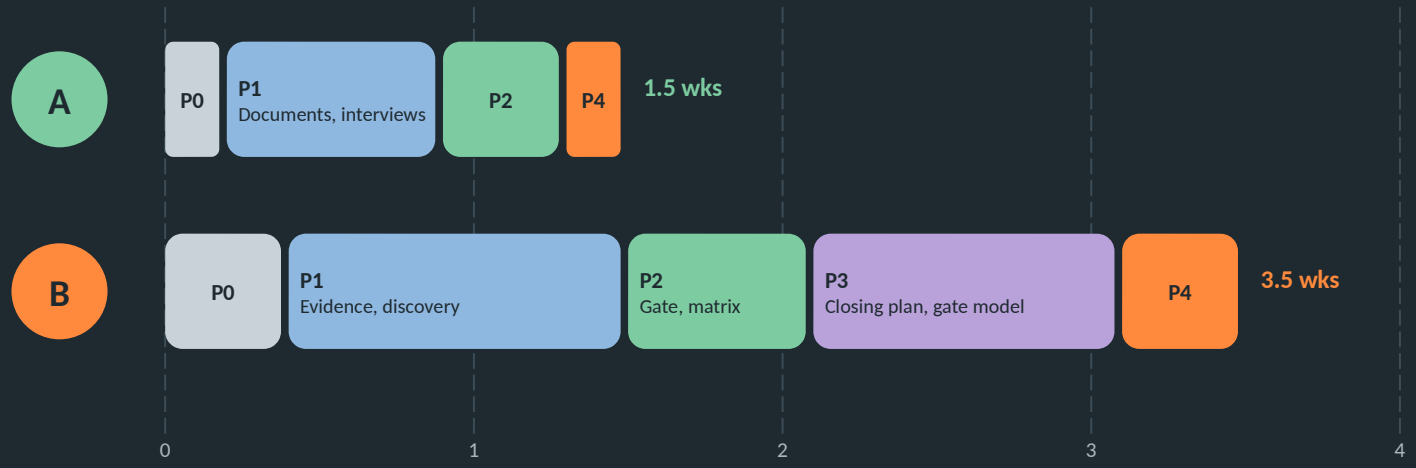
Statement
A · B

What an owner or a unit says — recorded as a claim

A gate item is “met” only where a document or a record supports it. In A, results rest mostly on statements and are marked as such.

System count sets the calendar. Each system needs its business and technical owner and, for personal data, the DPO; adding people does not shorten it.

PHASES BY SERVICE · M BAND, IN WEEKS



P0 scope · P1 evidence, discovery, interviews · P2 gate (A) or placement, gate, matrix (B) · P3 closing plan and gate model (B only) · P4 read-out

WHO DOES THE WORK

A — Assessment lead · AI governance consultant · AI / ML consultant

B — As A, plus regulation and risk consultant · data architect · third-party and platform specialist · organisation consultant

EVIDENCE BY SERVICE

A — No system access. Declared system list, policies, role definitions and any inventory, plus owner interviews per system.

B — No access model. Adds observation, a limited shadow AI search and, where shared, inventory, approval and incident records.

Process — P0 to P4

KOMTAS

Five phases, each with a written rule. A runs P0, P1, P2 and P4; P3 is B only. Phase length changes with the band, phase content does not.

P0 · Scope and system list

A 1 day · B 2 days

- AI systems in scope named («AI SYSTEMS»)
- Business and technical owners and interviewees set
- B: shadow AI search sources agreed
- B: target level per dimension agreed in writing

PHASE RULE

No work without an AI system in use or planned for production; if there is none, P0 stops the work

P1 · Evidence, discovery, interviews

A 3–4 days · B 1–1.5 wks

- Owner, committee, DPO, legal, risk and security interviews
- Inventory, policies, approval records, contracts
- B: shadow and vendor AI search: survey, procurement, licences, logs if shared
- B: one system followed from request to production

PHASE RULE

Each item is typed as measurement · document · observation · statement and the type is recorded

P2 · Gate and placement

A 2 days · B 3 days

- Gate run per AI system: met, partly, not met, not assessed
- Risk class per system with rationale, indicative
- B: dimensions placed on the ladder
- B: governance matrix and regulatory scope map

PHASE RULE

The gate is run for each AI system separately; the organisation gets no single governance grade

P3 · Closing plan and routing

B only · 1 week

- Gaps put in closing order, high risk first
- Each tied to owner, date and dependency
- Target role and gate model sketched by risk class
- Routing to follow-on work

PHASE RULE

Every gap is tied to an owner and a date; a gap without an owner does not close

P4 · Validation and publication

A 1 day · B 2 days

- Factual review with owners, legal and risk
- Objections recorded next to the finding
- Risk classes marked indicative until confirmed
- Baseline retained for the next assessment

PHASE RULE

An objection is not resolved away; “it was approved” is recorded with the approval record or its absence

SYSTEMS AND SHADOW SEARCH, NOT ACCESS, DRIVE THE SCHEDULE

P1 grows with AI systems and business units; each system needs its business and technical owner and, for personal data, the DPO. Narrowing the system list or the shadow search sources is a stronger schedule lever than dropping dimensions.

NO AI SYSTEM IN USE, NO ASSESSMENT (P0)

If P0 finds no AI system in use or planned for production, the work stops there. The fitting service is AI Readiness, proposed separately; governance without a system to govern produces no decision.

Prerequisite Gate — Per AI System

KOMTAS

Five items, run per AI system in both services. Independent of the ladder: an unmet item cannot be offset by high levels elsewhere.

	GATE ITEM	WHAT IT MEANS	HOW IT IS VERIFIED	IF NOT MET
1	**Registered**	The system is recorded in an inventory with a named business owner and technical owner	Inventory record; owner assignment	The system cannot be classified or approved; nobody answers for its results
2	**Classified**	Purpose and affected decision written; risk class assigned with rationale and date	Classification field or record, with rationale and date	Obligations are unknown; a high-risk use can run as if it were minimal
3	**Lawful data use**	Data sources, personal data status and legal basis written (DPIA where needed); contract constraints checked for third-party AI	Legal basis record, DPIA, vendor contract review	Data is used without a written basis; this cannot be fixed afterwards
4	**Approved with a way back**	A named approver approved production use; a human oversight point and a rollback / switch-off plan exist	Approval record with name and date; rollback plan	The system runs in production without a decision and cannot be stopped in a controlled way
5	**Monitored**	At least one metric with a threshold, an incident path and a periodic review date	Monitoring report or dashboard, incident record, review minutes	Drift or an incident goes unnoticed; the system is not under control

FOUR STATUSES PER ITEM, THREE RESULTS PER SYSTEM

Each item is recorded as met, partly met, not met or not assessed; “not assessed” is never counted as met. Each system is then governed, partly governed or not governed: governed = all five met, none not assessed; not governed = not registered, no business owner or in production without approval; otherwise partly.

A REJECTED REQUEST IS THE BEST EVIDENCE FOR ITEM FOUR

An approval mechanism that has never rejected a request is record keeping, not control; this is the first question in an audit. Item four therefore asks for the approval record and for a request that was rejected or returned.

Governance Matrix — AI Systems × Gate Items

KOMTAS

The main output of B: which system is under control, what is missing and what is closed first. Illustrative example; A produces the same rows as an indicative view.

AI SYSTEM · RISK CLASS	REGISTERED	CLASSIFIED	LAWFUL DATA	APPROVED	MONITORED	RESULT	PRIORITY · FIRST ACTION
Credit pre-scoring · high	Met	Met	Met	Not met	Partly	Not governed	1 · approval, rollback
CV screening, vendor · high	Not met	Not assessed	Partly	Not met	Not assessed	Not governed	1 · register, classify
Customer chatbot · limited	Met	Met	Partly	Met	Partly	Partly governed	2 · user notice, metric
Gen. AI subscriptions · shadow	Not met	Not met	Not assessed	Not met	Not met	Not governed	3 · inventory, usage rule
Document summarisation · minimal	Met	Met	Met	Met	Met	Governed	— · periodic review

THREE RESULTS

GOVERNED

All five items met; none "not assessed"

- Personal data without a written legal basis: never governed
- Kept on periodic review
- Re-classified when the purpose changes

PARTLY GOVERNED

Every other case

- E.g. registered with an owner, but monitoring or legal basis partly met
- Each gap gets an owner and a date
- Moves up as dates close

NOT GOVERNED

Not registered, no business owner, or in production without approval

- High risk without approval comes first
- Shadow and vendor AI often land here
- May lead to a controlled switch-off

WHY NO SINGLE GOVERNANCE GRADE IS PRODUCED

"The organisation's AI governance is 2.8 / 5" serves no decision. The report opens with a decision sentence instead:
"N systems are governed; system X (high risk) is in production without approval and must be closed first by …".

Lifecycle Gates by Risk Class

KOMTAS

The organisation's own control gates G1 – G6. B checks whether they exist and sketches which apply to which class; the assessment does not build them.

03 · METHOD · LIFECYCLE GATES

GATE · GATE RULE	MINIMAL No specific obligation	LIMITED Transparency	HIGH Strict obligations	UNACCEPTABLE Prohibited
G1 **Request and registration** No unregistered system is developed	● required	● required	● required	Not used. If found in the inventory, it is shut down.
G2 **Data and legal** No data used before the legal basis is written	◐ where applicable	◐ where applicable	● required	
G3 **Development and test** Acceptance criterion written in advance	— not required	◐ where applicable	● required	
G4 **Production release** No release without a rollback plan	— not required	● required	● required	
G5 **Operation and monitoring** A system not monitored counts as not in production	● required	● required	● required	
G6 **Retirement** Record closed, data and decision logs retained	● required	● required	● required	

High: G1 – G5 plus a written conformity assessment. Minimal and high follow the value deck; limited is an indicative sketch set per organisation in B.

ASSESSMENT GATE ITEM → LIFECYCLE GATE IT LOOKS FOR

1 Registered → G1	2 Classified → G1	3 Lawful data → G2	4 Approved → G4	5 Monitored → G5

The only evidence that a gate works is a rejected request. The same heavy process for every system gets governance abandoned fastest; gates scale with risk class.

Report Contents by Service

KOMTAS

Neither report is a maturity grade or a compliance statement. A gives an indicative view per declared system; B gives a decision per system and the plan behind it.

A · GOVERNANCE CHECK REPORT

- Gate status per item and declared system
- Indicative result and provisional risk class
- Key risks, e.g. high risk without approval
- Recommended next step
- Evidence inventory, reusable in B

B · GOVERNANCE READINESS REPORT

- Governance matrix with priority
- Risk class and regulatory scope per system
- Level per dimension, with evidence type
- Closing plan and target gate model
- Routing to follow-on work

IN NEITHER REPORT

- A single grade or weighted score
- A compliance or conformity statement
- Legal advice or a final risk class
- Certification, e.g. ISO/IEC 42001
- Validation of model accuracy

THE REPORT OPENS WITH A DECISION

Not “your AI governance maturity is at level n”, but “N systems are governed; system X (high risk) is in production without approval and must be closed first by …”. In A the same sentence is marked indicative and covers declared systems only.

SHADOW AND VENDOR AI BELONG IN THE INVENTORY

B runs a limited, evidence-based search: unit survey, procurement, expense and licence records, SaaS or network logs if shared, AI features of vendor products. A covers declared systems only and says so in the report.

FRAMEWORKS ARE HEADINGS, NOT CERTIFICATION

Risk classes follow the EU AI Act risk logic. The assessment maps findings to ISO/IEC 42001 and NIST AI RMF headings where useful; risk classes stay indicative until the organisation's legal or compliance confirms them.

Routing — Where Findings Lead

KOMTAS

Each route follows from a finding and its evidence. Routing is a consequence of the result, not a sales proposal.

03 · METHOD · ROUTING

IF THE FINDING IS …	… IT LEADS TO
Inventory or classification missing Gate items 1 · 2 · D1 · D2	**AI inventory set-up and classification**
High-risk system without approval or way back Gate item 4 · D3 · D8	**Control gates and pilot with one high-risk system**
No written policy or role model D3 · D4	**Policy and role model**
Intent to build a management system D10 · previous audit	**ISO/IEC 42001 preparation support**
Code written with AI to be assessed Outside D1 – D10	**Software audit**
New AI use cases planned Outside the gate · no system yet	**AI Readiness for new use cases**

BOUNDARY WITH AI READINESS

AI Readiness's governance dimension (A8) only checks that inventory, approval and classification exist, and routes here. No AI system in production → AI Readiness. The two are not sold at the same time.

NOT ROUTED HERE

Data quality and catalogue → Data Governance programme or Operational Data Governance Enablement. Statistical model accuracy → model risk management. Each follow-on has its own proposal.

A high-risk system without approval comes first. The closing plan orders gaps by risk class and production status, not by dimension; building the inventory precedes policy writing.

SECTION 4

Komtaş Side

Roles, duration, effort and sizing, deliverables and the proposal set, limits, package status and open items.

Competencies and roles p. 24

Duration, effort and sizing p. 25

Deliverables and proposal set p. 26

Limits of the assessment p. 27

Package status and open items p. 28

Competencies and Roles

KOMTAS

Which role is active in which phase, including customer participation. In A, Komtaş works with the assessment lead, the AI governance consultant and the AI / ML consultant; roles marked “B” join in B only.

ROLE	RESPONSIBILITY	PARTY	ACTIVE PHASES
Assessment Lead	Method, scope, gate per system and report	**Komtaş**	P0 – P4
AI Governance Consultant	Inventory, classification, policy, gate model (D1 – D3)	**Komtaş**	A P0 – P4 · B P0 – P3
Regulation and Risk Consultant	Regulatory scope map, risk classes, evidence capacity (D2, D10); no legal opinions	**Komtaş**	P1 – P3 · B
AI / ML Consultant	Documentation, testing, monitoring (D5, D7, D8)	**Komtaş**	A P1 – P2 · B P1 – P3
Data Architect	Data sources, lineage, data side of legal basis (D6)	**Komtaş**	P1 – P2 · B
Third-Party and Platform Specialist	Shadow AI and third-party AI search, vendor contracts (D9)	**Komtaş**	P1 – P2 · B
Organisation Consultant	Roles, AI committee, decision rights (D3, D4)	**Komtaş**	P1 – P3 · B
Project Sponsor	Risk, compliance, CDO or CIO; opens access to owners and management	**Customer**	P0, phase transitions
AI Committee	Policy, risk appetite, approval of high-risk systems	**Customer**	P1, P4
Business Owners	Purpose, use decision and ownership of results per system	**Customer**	P0 – P2
Technical Owners	Development, documentation, testing and monitoring	**Customer**	P1
DPO / KVKK, Legal, Compliance	Legal basis, DPIA, contracts; confirm risk classes	**Customer**	P1, P4
Risk, Security, Internal Audit	Class consistency, thresholds, incidents, control checks	**Customer**	P1

NO ASSESSMENT WITHOUT BUSINESS OWNERS

The business owner is the role most often missing. If no business owner can be named or interviewed for a system, gate item one is not met and the finding is recorded as such. Legal or compliance confirms risk classes; Komtaş does not give legal advice.

Duration, Effort and Sizing

KOMTAŞ

Indicative internal band values, pending delivery confirmation. The band is set from the short form; dates are fixed at kick-off, once interview calendars are known.

SERVICE	SMALL	MEDIUM	LARGE
A · AI Governance Check 5 gate items per declared system · documents, interviews	1 week · 6 pd · 3 days	1.5 weeks · 9 pd · 4 days	2 weeks · 12 pd · 5 days
B · AI Governance Readiness Assessment 10 dimensions · gate · shadow search · matrix · plan	3 weeks · 22 pd · 6 days	3.5 weeks · 28 pd · 8 days	4 weeks · 34 pd · 10 days

Cell format: duration · Komtaş person-days · customer days. Customer effort grows with AI systems and business units. In A with more than 20 systems, the gate is applied to high-risk and production systems first and to a sample of the rest; this is written in the assumptions.

SIZING DRIVERS

DRIVER	SMALL	MEDIUM	LARGE	USED IN
AI systems in scope	≤ 5	6 – 20	> 20	A · B
Business units using AI	1 – 2	3 – 6	> 6	A · B
People to interview	≤ 10	10 – 25	> 25	A · B
Third-party / vendor AI components	≤ 3	4 – 10	> 10	A · B
Applicable regulators	1	2 – 3	> 3	A · B
Legal entities or locations	1	2 – 3	> 3	A · B
Degree of regulation	Low	Medium	High	B
Documentation maturity	Written	Partial	None	B
Access to senior management calendar	Easy	Medium	Hard	B
Previous assessment or audit	Yes	Partial	No	B

BAND RULE · the highest band that at least three drivers fall into — A uses its 6 drivers, B all 10. One large driver alone does not set the band.

Deliverables and Proposal Set per Service

KOMTAS

Which documents each service produces, which package files are used to price it, who writes which proposal section, and where it usually leads.

SERVICE	DELIVERABLES	INPUT FORM · PROPOSAL TEMPLATE	USUAL NEXT STEP
A · AI Governance Check 1 · 1.5 · 2 weeks	· Gate status per item and declared system · Indicative result and provisional risk class, statement-based · Key risks with their evidence · Recommended next step; evidence inventory	3a-governance-check-girdi-formu 4a-governance-check-teklif-sablonu Question set 5: questions marked A Set 6, Proposal Set: S1 – S7	→ B · Governance Readiness → AI inventory set-up → AI Readiness, if no AI in use
B · AI Governance Readiness Assessment 3 · 3.5 · 4 weeks	· Ten dimensions, current and target, with evidence · Governance matrix: gate, risk class, priority per system · Regulatory scope map per system, three-state wording · Closing plan (owner, date, dependency); target gate model · Routing to follow-on work	3b-governance-readiness-assessment-girdi-formu 4b-governance-readiness-assessment-teklif-sablonu Question set 5: questions marked B Set 6, Proposal Set: S1 – S5, S8 – S14	→ AI inventory and classification → Control gates and pilot → Policy and role model → ISO/IEC 42001 preparation → Software audit

PROPOSAL STRUCTURE · WHO WRITES WHICH SECTION

Executive summary	Scope, AI systems	Method	Deliverables	Assumptions	Schedule, person-days	Team	Price	Terms
SAT	SAT	SAT · blueprint	SAT	SAT	Delivery	Delivery	Sales	Fixed

EVIDENCE IS REUSED, NOT BILLED TWICE

If B follows A, A's evidence inventory and gate results are reused. The proposal states this in writing and reduces P1 accordingly. A is not a mandatory step before B. One question set (5) and one internal set (6) serve both services.

SAT BOUNDARY

SAT produces the scope, the AI system list, the band and the first effort estimate. Delivery sets the duration, sales enters the price. SAT estimates independently first and challenges delivery's figure at the end; the challenge is recorded with its rationale either way.

Limits of the Assessment

KOMTAS

What this work does not do and does not guarantee is stated explicitly in the report itself

Not legal advice

Regulatory scope is mapped with three-state evidence wording. Interpretation and final risk classes belong to the organisation's legal and compliance.

No compliance statement, no certification

A statement of conformity can only be given by authorised bodies. ISO/IEC 42001 and NIST AI RMF are used as headings only.

Does not build

Inventory set-up, policy writing, committee set-up, gate implementation and tooling are separate follow-on work.

No model validation

The accuracy of statistical models belongs to model risk management; in banks, MRM teams own it.

No data quality or security testing

Data quality and catalogue belong to data governance. Security testing and code audit belong to the software audit, a separate service.

No complete inventory guaranteed

The shadow AI search in B is limited to the sources the organisation shares. A covers declared systems only.

THE MOST MISUNDERSTOOD LIMIT

Organisations often expect a “we are compliant” statement from this work. The assessment measures and produces evidence; it does not certify.
The wording is three-state: evidence provided, partial evidence, no evidence produced.

THE DECISION BELONGS TO THE ORGANISATION

The report shows which system is not under control; whether to approve, stop or retire it is the organisation's decision.
The matrix does not replace the AI committee.

OBJECTIONS ARE RECORDED, NOT RESOLVED

“It was approved” is a common objection; it is recorded next to the finding with the approval record or its absence.

Package Status and Open Items

KOMTAS

Files 0 – 6 of the AI Governance Readiness Assessment package are built, each in Turkish (-tr) and English (-en). Four points remain to settle before the first proposal.

FILE · ai-governance-readiness-assessment...	PURPOSE	AUDIENCE
...-0-surec-akisi	Process flow from first contact to proposal	internal
...-1-blueprint	This document: services, method, sizing	internal
...-2-musteri-sunumu	Customer deck: two services, about 20 minutes plus appendix	customer
...-3a / 3b-...-girdi-formu	Input forms for A and B with the declared AI systems table	internal
...-4a / 4b-...-teklif-sablonu	Proposal templates, numbered AGA / AGB	customer
...-5-musteri-soru-seti	Customer question set, questions marked A · B, A or B	customer
...-6-ic-soru-seti	Internal question set; Proposal Set S1 – S14	internal

WHAT CUSTOMER FILES DO NOT CONTAIN

No internal effort figures, no internal service or decision codes, no customer names. Follow-on work appears only as “separate service” or “separate proposal”. Regulatory content is shown only as in the value deck, with the date of compilation, the “not legal advice” note and the three-state evidence wording.

OPEN ITEMS

1 Durations and efforts not calibrated

Values mirror the readiness family, not AI governance projects. The family doc's first estimate was 4 · 6 · 9 weeks and 30 · 50 · 78 pd for one service; shadow AI search may push L higher. Delivery to confirm.

2 Regulatory content dated October 2026

EU AI Act dates and the Türkiye framework are as of October 2026 and are reconfirmed before each use.

3 Legal / compliance partner not decided

Who interprets regulation and signs off risk classes — the customer's legal team or a partner firm — is to be decided.

4 Implementation service not yet a package

AI inventory set-up and control gates are named as follow-on work but have no package, effort or proposal template yet.